UNIVERSIDAD NACIONAL DE INGENIERÍA

"Ciencia y Tecnología al Servicio del País"

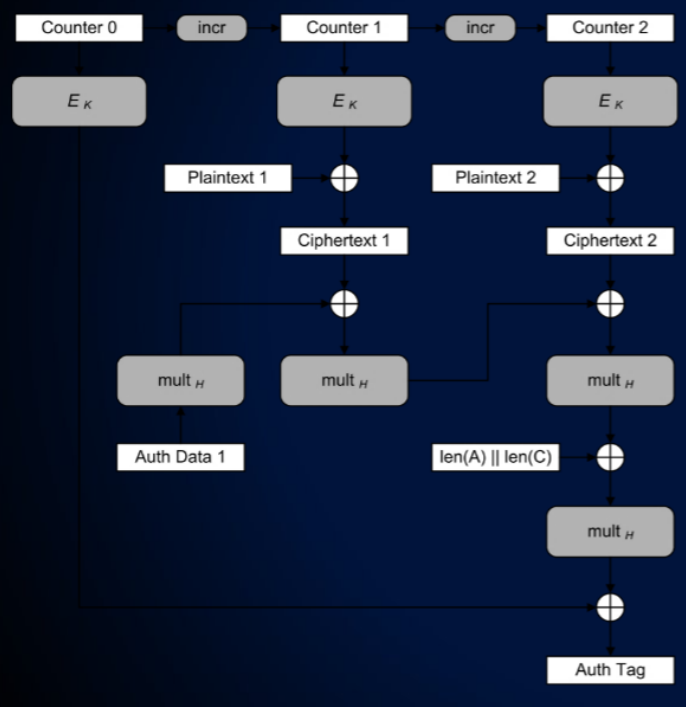
AES-GCM CIPHER

AES GALOIS/COUNTER MODE (GCM)

- GCM ES UN CIFRADO DE "CIFRADO CON AUTENTICACIÓN" (AEAD: AUTHENTICATED ENCRYPTION WITH ASSOCIATED DATA).
- NO SOLO OCULTA LA INFORMACIÓN, SINO QUE GARANTIZA QUE NO HAYA SIDO ALTERADA.
- UTILIZA EL MODO CONTADOR (CTR) PARA EL CIFRADO Y UNA FUNCIÓN DE AUTENTICACIÓN BASADA EN CAMPOS DE GALOIS (GHASH) PARA GENERAR UN TAG (SELLO DE AUTENTICACIÓN).
- ES ALTAMENTE PARALELIZABLE, LO QUE LO HACE EXTREMADAMENTE RÁPIDO EN PROCESADORES MODERNOS.

- *OPERACIÓN*
  - $C_i = AES_K(counter) \oplus P_i$
- *FLUJO*
  - *CAPA DE CIFRADO (MODO CONTADOR).*
  - *CAPA DE AUTENTICACIÓN (GHASH).*
- *UTILIZA:*
  - *IV.*
  - *CONTADOR.*
  - *AAD (ADDITIONAL AUTHENTICATED DATA).*
- *SEGURIDAD:*
  - *EL CERTIFICADO DE AUTENTICIDAD EMITIDO (AUTH TAG), GARANTIZA QUE EL MENSAJE ES LEGÍTIMO.*
  - *AEAD: CONFIDENCIALIDAD (NADIE LO LEE) E INTEGRIDAD (NADIE LO CAMBIA).*

AES GCM



- *AUTH DATA 1: SON DATOS QUE QUIERES PROTEGER, PERO NO CIFRAR (COMO EL ENCABEZADO DE UN PAQUETE IP). SE CONOCEN COMO AAD (ADDITIONAL AUTHENTICATED DATA).*
- $mult_H$ *: ES UNA MULTIPLICACIÓN EN UN "CAMPO DE GALOIS". ES UNA OPERACIÓN MATEMÁTICA COMPLEJA QUE ASEGURA QUE CUALQUIER CAMBIO MÍNIMO EN EL MENSAJE ALTERE COMPLETAMENTE EL RESULTADO FINAL.*
- *EL RESULTADO ES EL AUTH TAG: SI UN HACKER CAMBIA UN SOLO BIT DEL TEXTO CIFRADO DURANTE EL ENVÍO, CUANDO EL RECEPTOR HAGA ESTE MISMO CÁLCULO, EL TAG NO COINCIDIRÁ Y SABRÁ QUE EL MENSAJE FUE MANIPULADO.*

SERVICIOS AES GCM

- SERVICIO DE INTEGRIDAD: ¿EL MENSAJE HA SIDO ALTERADO?
- LA INTEGRIDAD GARANTIZA QUE LA INFORMACIÓN NO HAYA SIDO MODIFICADA POR UN TERCERO (YA SEA POR UN ERROR TÉCNICO O UN ATAQUE MALINTENCIONADO) DESDE QUE SALIÓ DEL EMISOR.
- EN EL ALGORITMO: SE LOGRA MEDIANTE LA CADENA DE MULTIPLICACIONES $mult_H$. SI UN ATACANTE CAMBIA UN SOLO BIT EN EL CIPHERTEXT 1, EL RESULTADO QUE ENTRA A LA SIGUIENTE CAJA DE MULTIPLICACIÓN CAMBIA DRÁSTICAMENTE.
- PROTEGE CONTRA ATAQUES BIT-FLIPPING

- SERVICIO DE AUTENTICACIÓN: "¿QUIÉN ENVIÓ REALMENTE ESTE MENSAJE?"
- VERIFICA LA IDENTIDAD DEL EMISOR (ESPECÍFICAMENTE LA AUTENTICACIÓN DE ORIGEN DE DATOS) GARANTIZA QUE EL MENSAJE FUE CREADO POR ALGUIEN QUE POSEE LA LLAVE SECRETA COMPARTIDA.
- EN EL ALGORITMO: SE LOGRA PORQUE EL AUTH TAG FINAL ES EL RESULTADO DE CIFRAR EL ACUMULADO DE LAS OPERACIONES CON LA LLAVE SECRETA K (A TRAVÉS DEL E_K DEL $COUNTER\ 0$).
- SOLO ALGUIEN CON LA LLAVE CORRECTA PUEDE GENERAR UN TAG VÁLIDO PARA UN CUERPO DE MENSAJE ESPECÍFICO.
- PROTEGE CONTRA ATAQUES DE SUPLANTACIÓN.

CBC VERSUS GCM

CARACTERÍSTICA	AES-CBC	AES-GCM
TIPO	CONFIDENCIALIDAD.	AEAD (CONFIDENCIALIDAD + AUTENTICACIÓN) INTEGRIDAD.
PARALELISMO	NO (SECUENCIAL).	SÍ (ALTA EFICIENCIA).
RELLENO (PADDING)	REQUIERE (PKCS#5/7).	NO REQUIERE.
RESISTENCIA	VULNERABLE AL PADDING ORACLE ATTACK.	RESISTENTE A ATAQUES DE INTEGRIDAD.
USO COMÚN	SISTEMAS LEGADOS.	TLS 1.2/1.3, ALMACENAMIENTO MODERNO.

FORTALEZAS Y DEBILIDADES

	AES-CBC	AES-GCM
FORTALEZA	ESTÁNDAR MUY BIEN COMPRENDIDO Y SOPORTADO UNIVERSALMENTE	PROVEE INTEGRIDAD AUTOMÁTICA. MUY EFICIENTE EN HARDWARE CON INSTRUCCIONES AES-NI.
DEBILIDAD	SI EL IV SE REUTILIZA O ES PREDECIBLE, LA SEGURIDAD SE DESPLOMA PERMITIENDO ATAQUES DE NEGACIÓN DE MENSAJE (ATAQUE BEAST). EL MANEJO DEL PADDING ES UN VECTOR DE ATAQUE COMÚN.	EL IV (NONCE) NUNCA DEBE REPETIRSE PARA LA MISMA LLAVE. SI SE REPITE UN NONCE EN GCM, SE PUEDE EXPONER LA LLAVE DE AUTENTICACIÓN.

UNIVERSIDAD NACIONAL DE INGENIERÍA

¡MUCHAS GRACIAS!